DuocUC

EVALUACIÓN PARCIAL 4 · DEFENSA INDIVIDUAL

Seguridad y calidad del Sistema Atlas

Verificación técnica de calidad, seguridad y cumplimiento normativo mediante ejecución de pruebas.

Integrantes: **Elías Delgado Manríquez · Rolando Aldana** ISY1102 · Sección **004V** Docente: **Johnnathan Cubillos** Grupo **15**

EL CASO EN UNA IDEA

Atlas guarda datos de varias empresas en un mismo lugar. Si esos datos se cruzan, no es solo un bug.

CALIDAD
Sistema transaccional multiempresa, criticidad media-alta.

SEGURIDAD
Datos personales y bancarios con control de acceso por empresa.

CUMPLIMIENTO
Tratamiento de datos de terceros bajo ley chilena.

Un mismo defecto de autorización golpea los tres ejes a la vez. Por eso el aislamiento entre empresas encabeza la prioridad del plan.

ENFOQUE ESTRATÉGICO DE LAS PRUEBAS

Mixto y basado en riesgo

Enfoque

Manual y automatizado

Suite automatizada de API y de carga, más la verificación manual de las respuestas de control de acceso.

Priorización

Primero el riesgo

Se prueban antes los casos que exponen datos de terceros: el aislamiento entre empresas y la inyección.

Entrada y salida

Criterios claros

Entrada: ambiente y datos listos. Salida: 100% de los casos ejecutados y los incidentes clasificados.

Ambiente QA local aislado, levantado desde la ERS y el contrato de pruebas definido por el equipo.

CRITERIOS DE CALIDAD, SEGURIDAD Y CUMPLIMIENTO

Tres marcos de referencia

Calidad

ISO/IEC 25010

- Adecuación funcional (CRUD)
- Desempeño: < 300 ms
- Usabilidad para adultos mayores

Seguridad

OWASP Top 10 · ASVS

- Control de acceso por rol y empresa (A01)
- Inyección, XSS y CSRF (A03)
- JWT de corta vigencia y TLS (A07/A02)

Cumplimiento

Ley 19.628 · Ley 21.719

- Protección de datos personales
- Resguardo de datos bancarios
- Acceso restringido a terceros

HERRAMIENTAS Y SU JUSTIFICACIÓN

Cada herramienta, un porqué

Postman / Newman

Ejecuta la colección de endpoints críticos con aserciones automáticas y repetibles sobre la API.

Pruebas de API · CP-01 a CP-06

Docker + Compose

Levanta API y base de datos en contenedores aislados sobre HTTPS, reproducibles en cualquier equipo.

Infraestructura · ambiente QA

Carga concurrente

Genera peticiones simultáneas y mide recursos con docker stats para evaluar resiliencia.

Rendimiento · CP-07

cURL

Peticiones dirigidas por caso para evidenciar cada resultado: el JWT, el acceso entre empresas y la inyección.

Inspección · evidencia por caso

DISEÑO DE CASOS DE PRUEBA

Seis casos representativos

CASO	QUÉ VERIFICA	REQUERIMIENTO	TIPO
CP-01	Autenticación y protección del token	RF-1.1 · NFR-SEG	Funcional / Seguridad
CP-02	Rol editor sin permisos de escritura	RB-4 · NFR-SEG-4	Seguridad
CP-03	Aislamiento de datos entre empresas	RB-2 · NFR-SEG-8	Seguridad / Cumplimiento
CP-04	Validación de datos de clientes	RF-4.3 · RB-5	Funcional
CP-06	Inyección, XSS y CSRF	NFR-SEG-5	Seguridad
CP-07	Resiliencia de contenedores bajo carga	NFR-PERF · NFR-DIS	No funcional

EJECUCIÓN DE PRUEBAS EFECTUADAS

100% ejecutado

4
en PASE

2
en FALLO

25
aserciones

7
fallidas

Los fallos se concentran en dos casos: aislamiento entre empresas (CP-03) e inyección XSS (CP-06). El análisis estático (Semgrep + npm audit) complementó la corrida y detectó 4 dependencias vulnerables.

	executed	failed
iterations	1	0
requests	14	0
test-scripts	14	0
prerequest-scripts	0	0
assertions	25	7
total run duration: 672ms		

Newman · corrida real de la suite Postman

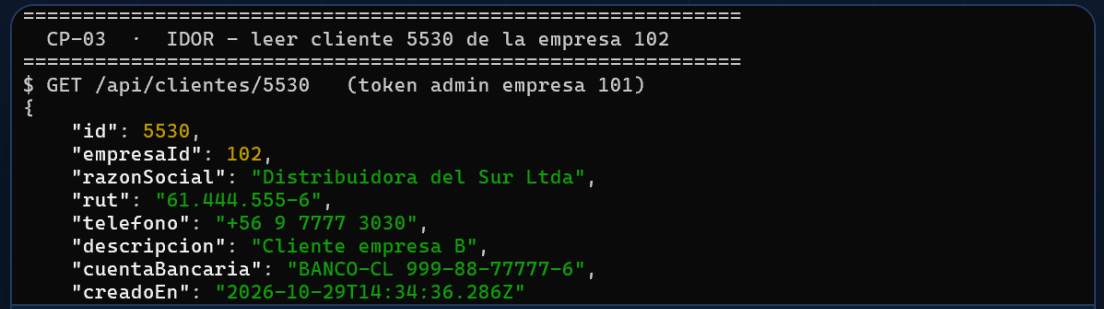
CLASIFICACIÓN DE DEFECTOS · HALLAZGO 1

IDOR entre empresas CRÍTICO

Un administrador de la empresa 101 leyó el cliente **5530** de la empresa 102 y obtuvo su **RUT y cuenta bancaria**.

Caso: **CP-03** HTTP **200** OWASP **A01** **Ley 19.628**

> **Remediación:** resolver la autorización en el backend comparando la empresa del token con la del recurso en cada petición.



$ GET /api/clientes/5530 — datos de un tercero expuestos

CLASIFICACIÓN DE DEFECTOS · HALLAZGO 2

Stored XSS GRAVE

La descripción del cliente se **almacena y devuelve sin escapar** y la respuesta no incluye cabecera CSP.

Caso: **CP-06** HTTP **201** OWASP **A03** **Ley 21.719**

> **Remediación:** validar y escapar la entrada, y añadir cabeceras de seguridad, entre ellas una Content-Security-Policy restrictiva. SQLi y CSRF sí fueron mitigados.

```
============================================================
  CP-06  ·  XSS almacenado + ausencia de CSP
============================================================
$ POST /api/clientes  descripcion=<script>alert('xss')</script>
{
    "id": 6001,
    "empresaId": 101,
    "razonSocial": "Cliente XSS",
    "rut": "76.123.456-0",
    "telefono": null,
    "descripcion": "<script>alert(1)</script>",
    "cuentaBancaria": null,
    "creadoEn": "2026-10-29T14:48:37.291Z"
}
Cabeceras de seguridad:
   (ninguna cabecera de seguridad presente)
```

$ POST /api/clientes — script almacenado, sin CSP

RESILIENCIA Y ESCALA DE CRITICIDAD

La infraestructura resistió

`200 peticiones concurrentes → 200 OK`

Sin reinicios ni caídas; memoria estable. CP-07 en ● PASE

CRÍTICO bloquea / expone datos de terceros

GRAVE vector explotable, con corrección urgente

```
============================================================
  CP-07  ·  Carga y resiliencia
============================================================
>> docker stats ANTES:
NAME        CPU %     MEM USAGE / LIMIT
atlas-api   0.00%     18.48MiB / 11.39GiB
atlas-db    0.00%     26.75MiB / 11.39GiB
>> 200 peticiones GET concurrentes a /api/clientes ...
   200 x HTTP 200
>> docker stats DESPUES:
NAME        CPU %     MEM USAGE / LIMIT     NET I/O
atlas-api   0.01%     29.12MiB / 11.39GiB   771kB / 889kB
atlas-db    0.00%     43.53MiB / 11.39GiB   110kB / 206kB
>> Contenedores:
NAMES       STATUS
atlas-api   Up 14 minutes
atlas-db    Up 14 minutes (healthy)
elias@RogZephyrus:~/atlas-qa-lab$
```

CP-07 · carga concurrente y docker stats

REFLEXIÓN ÉTICA Y NORMATIVA

Qué significan los resultados

Ley 19.628	El IDOR expone datos personales y bancarios de terceros; de llegar a producción incumpliría la ley y expondría a CreaLab a un riesgo legal, no solo técnico.
Ley 21.719	El XSS evidencia que falta seguridad desde el diseño y responsabilidad proactiva en la validación del lado del servidor.
Profesional	Ambas vulnerabilidades deben remediarse antes de producción para resguardar confidencialidad, integridad y disponibilidad.

CIERRE

El control de acceso es la prioridad. Resuelto el IDOR y el XSS, Atlas queda listo para avanzar.

¿PREGUNTAS?